SOW1 - SOW2 secure communication: overview and requirement review

Sources: Polarion export "readyForReview" (concept: 25 requirements for this interface; technical: 30), Volvo Camera Interface Specification D040574 v1.0 (section 11), SRS rev. 731696 chapter 23.2. Every **Decision** is left `OPEN` for you.

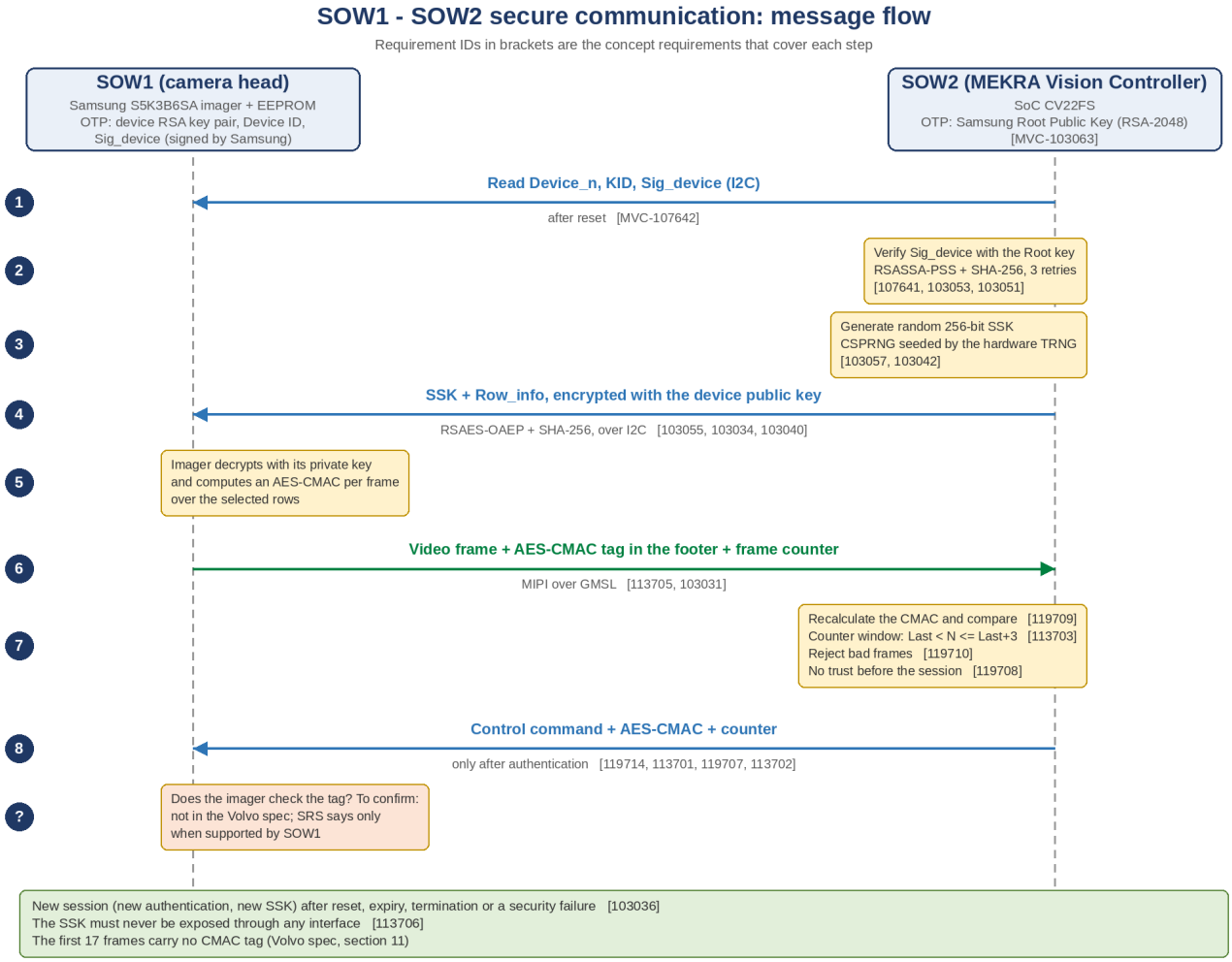
Entry format: SIQ (only when one exists), Impact and proposal, Testability Finding, Technical Finding, Structure Finding, Traceability Finding (`NONE` when there is nothing), then **How to test** in pseudo-code.

Part 1. Overview of the feature

In one paragraph

SOW2 (our MEKRA Vision Controller) must be sure that the camera head (SOW1: Bosch camera with a Samsung S5K3B6SA imager) is a genuine one, and that the video and the commands between them cannot be forged, replayed or changed by someone who plugs in a fake camera or injects data on the cable.

The flow, step by step



Where the 25 requirements sit

Step	Concept requirements
Root key	103063
Authentication of the camera	107642, 107641, 103053, 103051
Session key and key sharing	103040, 103057, 103042, 103055, 103034, 113706, 103046, 103044, 103036
Video from camera to ECU	119708, 113705, 103033, 119709, 119710, 103031, 113703
Commands from ECU to camera	119714, 113701, 119707, 113702

What this feature does not cover (found while reading)

1. **Camera EEPROM signature.** The Volvo spec says the ECU must verify the Bosch signature of the EEPROM read-only data before using it. No concept requirement covers that.
2. **Session lifetime.** "Session expiry" is a trigger in MVC-103036, but no requirement defines a lifetime.
3. **The first 17 frames.** The imager sends no CMAC for them. Nothing says how to treat them.
4. **Authenticated commands.** The Volvo spec does not describe authenticated control commands at all. The SRS says the tag is added only when the camera supports it.
5. **Samsung documents are missing in the repo:** the cybersecurity application note (Rev 0.27, defines Device_n, KID, Row_info and the message layout), the key provisioning policy and the key fusing guide.

Test setup used in the pseudo-code

Name	Meaning
SIM	A SOW1 simulator we still have to build or buy. Answers I2C like the imager, holds the device private key, signs with a **test root key**, and can send frames with correct or wrong CMAC and counters. A real imager cannot do the negative cases
Saleae	Logic analyser on the SoC to deserializer I2C bus (the imager's I2C is tunnelled through it)
Lauterbach	Debugger on the SoC: read or write memory and registers, set breakpoints, force return values
TE-1190	Technica GMSL capture module: captures I2C, GPIO and the MIPI video
Wireshark	On the Ethernet side: the outgoing RTP video and the SOME/IP traffic
PyRef	A small Python script with an independent crypto library to compute CMAC, RSA-PSS and RSA-OAEP reference values

Part 2. Requirement review

#	Requirement	Topic	Status
1	MVC-119709	Verify frame tag	reviewed
2	MVC-119710	Reject frame on failure	reviewed
3	MVC-113705	Extract tag from footer	reviewed
4	MVC-103033	Calculate frame CMAC	reviewed
5	MVC-103031	Extract frame counter	reviewed
6	MVC-113703	Freshness window	reviewed
7	MVC-119708	No trust before session	reviewed
8	MVC-103063	Root key in OTP	reviewed
9	MVC-107642	Authenticate imager	reviewed
10	MVC-107641	RSASSA-PSS with SHA-256	reviewed
11	MVC-103053	Retry authentication	reviewed
12	MVC-103051	Terminate authentication	reviewed
13	MVC-103040	Extract device public key	reviewed
14	MVC-103057	Generate 256-bit SSK	reviewed
15	MVC-103042	CSPRNG and TRNG	reviewed

#	Requirement	Topic	Status
16	MVC-103055	Encrypt SSK and Row_info	reviewed
17	MVC-103034	Transmit encrypted SSK	reviewed
18	MVC-113706	Do not expose SSK	reviewed
19	MVC-103046	Retry session establishment	reviewed
20	MVC-103044	Terminate session establishment	reviewed
21	MVC-103036	New session after triggers	reviewed
22	MVC-119714	No commands before authentication	reviewed
23	MVC-113701	CMAC over each command	reviewed
24	MVC-119707	Append tag to command	reviewed
25	MVC-113702	Command counter	reviewed

1. MVC-119709 (2.2.1.1.4-4), CAL 2, Test

> *The system shall verify the integrity and authenticity of each video frame by comparing the calculated AES-CMAC tag with the 128-bit CMAC tag received in the frame footer.*

Technical requirement: MVC-106582. Test: CS-SOW1-021.

SIQ

- SIQ-1 (concept owner, Bosch, Volvo): the Volvo spec says the CMAC is available only from the 18th frame ("the first 17 frames are without the AES-CMAC Tag"). How must SOW2 treat frames 1 to 17: accept as untrusted, drop, or show? Do the 17 frames count from stream start or from the moment the key reaches the imager?
- SIQ-2 (Samsung, Bosch): the tag covers only the rows chosen by Start H, Interval H, Total H. Which rows does our concept choose, and is a sparse selection accepted as residual risk?

Impact and proposal

- Impact: the text says every frame is verified. The imager cannot do that. A tester has no pass criterion for frames 1 to 17, and a reader may think the whole frame is protected.
- Proposal: reword to "…each SOW1 video frame that carries an AES-CMAC tag, by comparing the 128-bit tag calculated over the selected rows with the tag received in the frame footer". Add a separate requirement for the frames without a tag. Add that this applies from C1-sample on (the B1/B2-sample settings table in the Volvo spec lists AES-CMAC as "None").

Testability Finding

- The comparison is internal. Only the outcome is visible (accepted, rejected, log entry), which is the same observable as 119710. Proposal: use the security log entry that SRS MVC-108108 already requires as the pass criterion for both.
- "Invalid tag" is not defined. Use: one flipped bit in the tag, truncated tag, tag from another session key, all-zero tag, correct tag on modified data.
- A test needs the session key to build a valid frame, but 113706 forbids exposing it. With a real imager the tester cannot know the key. A SIM that holds the device private key can decrypt the key that SOW2 sends, so it is the base setup.

Technical Finding

- The wording overstates the protection: unselected rows, statistics and other data are not authenticated, and MVC-103033 itself says "selected rows". Record which attacks the sparse selection stops and which not.
- Frames 1 to 17 (SIQ-1).
- No latency limit for holding a frame until it is verified. The frame-timing analysis (`Analysis/SG2_Frame_Timing_Requirements_Analysis.docx`) was not checked for one.

Structure Finding

- 119709 and 119710 describe one function in two halves, and the SRS has the same pair (MVC-108117, MVC-108116). Merge them, or make the split clear: 119709 defines the comparison, 119710 defines the reaction.
- The technical requirement MVC-106582 has exactly the same text. It should say the algorithm (AES-CMAC, 256-bit key, 128-bit tag), the input (rows set by MVC-106576, 108741, 106574, 106583) and that all 128 bits must match.

Traceability Finding

- Downstream link to MVC-106582 is fine, in both directions.
- Upstream: it links to MVC-106231, the same item that the debug and hardware-protection requirements link to, so it is not specific. MVC-106231 is not in the exports.
- SRS candidates: 23.2.5.2 (MVC-108122, 108112, 108117), no link in my files. The 17-frame rule is in no requirement.

How to test

```
SIM: build frame N with SSK_sim (decrypted from the key block SOW2 sent), selected rows, valid
tag
TE-1190: inject frame            -> expect: frame passed on (Wireshark: RTP packet appears;
log: no CMAC failure)
repeat with: tag bit flipped / tag truncated / tag from another key / tag = 0 / data row
modified, tag unchanged
                                 -> expect: each rejected, log entry "CMAC failed" (UART log)
partial match: tag with only first 64 bits right -> expect: rejected
```

Decision: OPEN

---

2. MVC-119710 (2.2.1.1.4-5), CAL 2, Test

The system shall reject any received SOW1 video frame if AES-CMAC verification fails.

Technical requirement: MVC-106564. Test: CS-SOW1-022.

Impact and proposal: "Reject" is not defined: dropped, replaced by the previous frame, or shown with a flag? This is a camera that drives a display, so a defined reaction matters. Proposal: state the reaction (drop the frame, count it, log it, keep processing the next frames, which SRS MVC-108105 already says) and when repeated failures start a new session (see 103036).

Testability Finding: the observable is the same as 119709. Define it once: dropped frame counter and log event. The VC step "does not cause the same invalid frame to be re-submitted" needs a defined internal buffer to look at.

Technical Finding: no limit on how many bad frames are tolerated before the stream is treated as an attack. A single corrupted frame from EMI on the cable would also fail the CMAC (the link has CRC, but the check here is separate). Question: do random corruption and a forged frame get the same reaction?

Structure Finding: overlaps 119709 (see entry 1). Overlaps SRS MVC-108116.

Traceability Finding: MVC-106564 (link both ways). SRS MVC-108116, 108108, 108105. Same upstream as 119709.

How to test

```
SIM: send 10 good frames, 1 frame with wrong tag, 10 good frames
Wireshark: RTP shows 20 frames, the bad one missing        -> expect: bad frame not forwarded
UART log: 1 "CMAC failed" entry                            -> expect: logged
Lauterbach: read dropped-frame counter                     -> expect: 1
SIM: send 1000 frames, each with a wrong tag                -> expect: defined reaction (new
session or stay up) once decided
```

Decision: OPEN

---

3. MVC-113705 (2.2.1.1.4-2), CAL 2, Test

The system shall extract the received 128-bit AES-CMAC authentication tag from the embedded footer of each received SOW1 video frame.

Technical requirement: MVC-106572. Test: CS-SOW1-019.

SIQ: where exactly is the footer in the frame (which line, which bytes, byte order) and what is its length when the tag is absent? Defined in the Samsung note (not in the repo).

Impact and proposal: without the layout the extraction cannot be implemented or tested. Add the layout reference to the technical requirement.

Testability Finding: extraction is internal. Either read the extracted value with Lauterbach, or infer it from acceptance, which makes it the same test as 119709. Missing or short footers need a defined reaction (the SRS says reject, MVC-108134).

Technical Finding: frame 1 to 17 have no tag (entry 1). The tag is described as 128 bits; whether the footer ever carries more (padding, status bits) is unknown.

Structure Finding: this is an implementation step of 119709, not a security property by itself. Proposal: keep it at technical level, or merge into 119709.

Traceability Finding: MVC-106572. SRS 23.2.5.1 (MVC-108140, 108129, 108134, 108132).

How to test

```
SIM: frame with known tag T = 0x00112233...  in the footer
Lauterbach: read the extracted-tag buffer          -> expect T
repeat with 10 different tags                      -> expect each equal (not hard-coded)
SIM: frame without footer / short footer / garbage -> expect: rejected, no crash, log entry
```

Decision: OPEN

---

4. MVC-103033 (2.2.1.1.4-3), CAL 2, Test

> *The system shall calculate a 128-bit AES-CMAC tag over the selected rows of each video frame using the active 256-bit session key.*

Technical requirements: MVC-106583. Test: CS-SOW1-020.

SIQ: exactly which bytes form the message: only the pixel and embedded data of the selected rows, or also the line headers/footers and CSI-2 packet bytes? Row numbering base? (Samsung note.)

Impact and proposal: two implementations could calculate different tags for the same frame. Add the exact message construction and a test vector from Samsung.

Testability Finding: a reference calculation (PyRef) works only if the tester knows the SSK and the exact input. With the SIM it is possible. A known-answer test vector from Samsung would make it independent of the SIM.

Technical Finding: AES-CMAC with a 256-bit key is standard (NIST SP 800-38B, AES-256). The requirement says "128-bit tag": full output, not truncated, should be stated. The interval rule in MVC-108741 (at least 10 or 30 rows) exists so the imager finishes one row before the next. The host side has no stated rule on how fast it must compute.

Structure Finding: it also says "selected rows", which are defined in four other requirements (103055 note, 106576, 108741, 106574). Better to give the row selection its own concept requirement and reference it here.

Traceability Finding: MVC-106583. SRS MVC-108122, 108121, 108118.

How to test

```
TE-1190: capture a real frame (raw rows)
PyRef:   tag_ref = AES256-CMAC(SSK, selected rows as defined)
SIM:     send the frame with tag_ref  -> expect: accepted
modify 1 byte in a selected row, keep tag_ref -> expect: rejected
modify 1 byte in a NOT selected row, keep tag_ref -> expect: accepted (shows the coverage
limit, record it)
```

Decision: OPEN

---

5. MVC-103031 (2.2.1.1.4-6), CAL 2, Test

> *The system shall extract the video frame counter from the embedded header data of each received SOW1 video frame and use the counter value for freshness validation.*

Technical requirements: MVC-113726 (extract) and MVC-106575 (verify freshness, ordering and sequence). Tests: CS-SOW1-025, CS-SOW1-023.

SIQ: size of the counter (bits), start value, behaviour at wrap-around, and whether the imager resets it at every stream start. (Samsung note.)

Impact and proposal: the window rule in 113703 cannot be checked at the wrap without the width. Add width and wrap behaviour.

Testability Finding: the counter is internal. Read it with Lauterbach. Boundary tests need the SIM to send chosen values, in particular near the maximum.

Technical Finding: the counter is only protected by the CMAC if the header line is among the selected rows (start row 0, MVC-106576). If it is not, the counter can be forged freely. State this dependency here.

Structure Finding: "extract and use for freshness" is two things, and the concept requirement is satisfied by two technical requirements, one for each. The "use" part (MVC-106575, freshness, ordering and sequence) overlaps MVC-113727, which belongs to 113703 (entry 6). Proposal: keep only the extraction here, and let 113703 own the validity rule.

Traceability Finding: MVC-113726 and MVC-106575 (CS-SOW1-023 has no entry of its own below, it is covered here and in entry 6). SRS MVC-108099.

How to test

```
SIM: frames with counter 1,2,3,...,N
Lauterbach: read extracted counter after each frame   -> expect: equal to SIM value
SIM: counter = 0xFFFF.. then 0 (width as defined)    -> expect: defined wrap handling
SIM: header missing / short                           -> expect: rejected, log entry
```

Decision: OPEN

---

6. MVC-113703 (2.2.1.1.4-7), CAL 2, Test

> *The system shall reject duplicated, stale, or out-of-order SOW1 video frames based on a 3-frame freshness window and shall accept a frame only when its frame counter satisfies LastAcceptedCounter < ReceivedCounter ≤ LastAcceptedCounter + 3.*

Technical requirement: MVC-113727. Test: CS-SOW1-026.

SIQ: counter width and wrap (entry 5). Initial LastAcceptedCounter after a new session.

Impact and proposal

- Impact: if more than 3 consecutive frames are lost (link problem, brief disturbance, SoC load), every later valid frame has a counter above LastAcceptedCounter + 3 and is rejected. The stream stays dead until a new session. For a safety-relevant camera that is an availability problem.
- Proposal: define a recovery: after N consecutive frames rejected only because of the window, but with valid CMAC, re-synchronise LastAcceptedCounter. Or end the session and renegotiate, and say which.

Testability Finding: the boundaries in the requirement are good and easy to test with the SIM (equal, lower, +1, +2, +3, +4). Wrap-around and the first frame of a session cannot be tested until they are defined.

Technical Finding

- Order of checks: update LastAcceptedCounter only after the CMAC passed. Otherwise a forged frame with a high counter can push the window forward and block genuine frames. State the order.
- No behaviour for the first frame of a session.

Structure Finding: NONE.

Traceability Finding: MVC-113727. SRS MVC-108099, 108104, 108102. The recovery behaviour is in no requirement.

How to test

```
SIM: frames with valid CMAC, counters:  10 accepted
send 10 (dup)         -> reject        send 9 (stale)  -> reject
send 11 -> accept     send 13 -> accept (Last=11, +2 ... within +3)
send 17 (Last+4)      -> reject
send frame, counter forged high (valid format, WRONG tag) -> reject, Lauterbach:
```

```
LastAcceptedCounter unchanged
skip 5 frames, then valid CMAC frames -> observe: recovery as defined
```

Decision: OPEN

---

7. MVC-119708 (2.2.1.1.4-1), CAL 2, Test

> *The system shall not accept SOW1 secured video stream data as trusted before successful SOW1 device authentication and secure session establishment.*

Technical requirement: MVC-109120. Test: CS-SOW1-024.

SIQ (safety): what does the system do with video that is "not trusted"? Drop it (no image for the driver) or pass it with an "untrusted" flag? This is a camera for the vehicle; both the safety and security teams must agree.

Impact and proposal: "not accept as trusted" can be implemented in two very different ways. Define the reaction and who evaluates it (the downstream display side, the vehicle ECU, or SOW2). Cross-check with frames 1 to 17 (entry 1).

Testability Finding: the observable is the outgoing stream (Wireshark on RTP) and a status signal if one exists. If "untrusted" is only an internal flag, there is nothing to check from outside.

Technical Finding: "secure session establishment" has no definition of when it is complete (imager acknowledgement? first good CMAC?). See entry 17.

Structure Finding: NONE.

Traceability Finding: MVC-109120. SRS MVC-108138. The reaction is in no requirement.

How to test

```
reset, SIM does not answer authentication
SIM: send frames (valid CMAC, any key)        -> Wireshark: no trusted video out / flagged as
untrusted
reset, authentication OK, key block not acknowledged -> same
terminate session, SIM keeps sending frames of the old session -> rejected
complete authentication + session -> Wireshark: video flows
```

Decision: OPEN

---

8. MVC-103063 (2.2.1.1.1-1), CAL 2, Test

> *The system shall store the trusted 2048bit Samsung Root Public Key in OTP memory.*

Technical requirement: MVC-106562. Test: CS-SOW1-001.

SIQ: which OTP zone holds it, and who programs it (Mekra factory, Ambarella) and when? The SRS secure-boot requirement mentions OTP "zone 7 [X]" as an open choice. The CV22FS manual describes the power-on-configuration OTP as factory-set and not user-accessible, and I did not find a customer-key zone in the manuals I have.

Impact and proposal: the test and the production flow depend on the zone. Proposal: name the zone and add "and shall prevent modification, replacement or deletion" (the technical verification criteria already test immutability, the requirement does not state it; SRS MVC-108142 does).

Testability Finding: OTP is write-once, so the "cannot be overwritten" test destroys a sample. Test samples need a **test root key**, because Samsung's private key is not available. A production sample can only be checked by comparing a hash if OTP is read-locked.

Technical Finding: the concept says OTP, SRS MVC-108143 says "protected non-volatile storage". Not the same. RSA-2048 public key = 256-byte modulus plus exponent: confirm the free OTP size.

Structure Finding: the technical requirement has the same text as the concept requirement.

Traceability Finding: MVC-106562. SRS 23.2.1 (MVC-108143, 108142, 108144). The secure-boot key (SRS 23.4) is a different root: make sure both are tracked.

How to test

```
Lauterbach: read OTP zone X (if allowed in this lifecycle) -> SHA-256(key) == fingerprint of
the Samsung root key
Lauterbach/SW: write to OTP zone X                          -> expect: rejected or locked
```

```
power cycle + reset                                          -> read again, expect same value
SIM signs auth data with the matching private key (test build)  -> authentication passes
SIM signs with another key                                   -> authentication fails
```

Decision: OPEN

---

9. MVC-107642 (2.2.1.1.2-1), CAL 2, Test

The system shall authenticate the Imager by verifying the digital signature received from the Imager over the I2C interface using the provisioned Samsung Root Public Key.

Technical requirements: MVC-106561, 106565, 106563. Tests: CS-SOW1-002, 003, 004.

SIQ

- SIQ-1 (Samsung): define Device_n, KID, Sig_device. The Volvo spec says the signature covers "the device specific RSA public key along with the Device ID". The technical requirement says "over Device_n and KID". Is Device_n the key modulus and KID the Device ID? And is KID a key or algorithm identifier? The SRS (MVC-108135, 108136) lets KID select the signature scheme and hash.

Impact and proposal: if the signed message is not defined byte for byte, SOW2 and the test cannot agree. Add the exact signed message and encoding to the technical requirement.

Testability Finding: needs signed data from the test root key. Negative cases (one field changed, other key) need the SIM.

Technical Finding

- The signature in the imager is a fixed value, stored in OTP and read over I2C. I found no challenge-response in the Volvo flow. A fake camera can copy the genuine data (it is not secret) and pass step 2. What stops it is that it does not hold the private key, so it cannot decrypt the session key and cannot produce a valid CMAC. Until the first valid tagged frame (frame 18 or later) SOW2 has no proof that the camera owns the key. Please confirm this is understood and accepted.
- The concept fixes the scheme (107641), while the SRS makes KID select the scheme. See entry 10.

Structure Finding: the concept requirement is verified by three technical requirements (request, verify, scheme). That is fine, but the pass criteria overlap. Keep each test about one thing.

Traceability Finding: concept to technical: three links. SRS 23.2.2 and 23.2.3 (MVC-108133, 108131, 108126, 108124, 108113, 108111).

How to test

```
SIM: serve genuine data (Device_n, KID, Sig_device signed by test root)
Saleae: capture auth read           -> expect: SOW2 asks for the fields; then accepts; key
block follows
SIM: flip 1 bit in Device_n / KID / Sig_device (one run each) -> expect: rejected, no key block
sent
SIM: signature from another key     -> expect: rejected
SIM: copy genuine data, no private key (replay) -> expect: auth accepted, but no valid CMAC
frame ever -> frames rejected
```

Decision: OPEN

---

10. MVC-107641 (2.2.1.1.2-2), CAL 2, Test

The system shall use RSASSA-PSS with SHA-256 to verify the Imager's digital signature.

Technical requirement: MVC-106563 (no link back in Polarion). Test: CS-SOW1-004.

SIQ: PSS parameters: salt length, mask generation function (MGF1 with SHA-256?). And the SRS lets KID choose scheme and hash (MVC-108135, 108120). Is PSS with SHA-256 the only supported one?

Impact and proposal: if only one scheme exists, tell the SRS to drop the selection by KID. If KID selects among several, this requirement must say which values of KID are accepted.

Testability Finding: partly an inspection (the technical verification criteria say "implementation inspection"). The black-box part: signatures made with PKCS#1 v1.5, other hashes or other salt lengths must fail. The salt-length case cannot be written until the salt is defined.

Technical Finding: salt length, MGF and exponent are not stated.

Structure Finding: it is a property of the verification in 107642, not a stand-alone behaviour. Proposal: merge into 107642 or keep as a technical detail.

Traceability Finding: the technical requirement MVC-106563 does not link to it (only to 107642). Add the link. SRS MVC-108120, 108135, 108136.

How to test

```
Code review: verify call = RSASSA-PSS + SHA-256 (CS-SOW1-004 step 1)
PyRef: sign (Device_n||KID) with test root key:
   PSS+SHA-256   -> SIM serves -> expect: accepted
   PKCS#1 v1.5   -> expect: rejected
   PSS+SHA-1 or SHA-384 -> expect: rejected
   PSS+SHA-256, other salt length -> expect: as defined (once the salt is fixed)
```

Decision: OPEN

---

11. MVC-103053 (2.2.1.1.2-3), CAL 2, Test

> *The system shall retry the Imager authentication process up to three times if the expected authentication data is failed to be received.*

Technical requirement: MVC-106566. Test: CS-SOW1-005.

SIQ: three retries (4 requests) or three attempts (3 requests)? MVC-106569 says "three authentication attempts". One number is needed. Also the timeout per attempt and the time between attempts.

Impact and proposal: a test that counts requests on the bus cannot pass or fail without it. Proposal: "N attempts in total, each with timeout T".

Testability Finding: counting requests with Saleae is easy. Withholding the answer needs the SIM or a way to cut the I2C response. Timing cannot be checked until T exists.

Technical Finding: what is "not received": no ACK, partial answer, timeout, or malformed? A complete but invalid answer is a signature failure (reject at once?). Define.

Structure Finding: the retry rule is split over two requirements (103053 retry, 103051 terminate) that use different words ("up to three retries" and "configured maximum").

Traceability Finding: MVC-106566. SRS MVC-108124, 108126.

How to test

```
SIM: do not answer the authentication read; reset
Saleae: count auth read requests until SOW2 stops   -> expect: N (as decided)
SIM: answer correctly on request 2                  -> expect: authentication continues
Saleae: measure time between requests               -> expect: equals T (once defined)
```

Decision: OPEN

---

12. MVC-103051 (2.2.1.1.2-4), CAL 2, Test

> *The system shall terminate the Imager authentication process if authentication is not successfully completed within the configured maximum number of retry attempts*

Technical requirement: MVC-106569. Test: CS-SOW1-006.

SIQ (safety): after termination, what does the ECU do: stay without video, try again later, or enter a safe state? And when is another attempt allowed (only after reset?).

Impact and proposal: this is a cybersecurity failure that can switch off a camera image. Define the system reaction together with the FuSa team. Proposal: add the reaction and the rule for a later new attempt.

Testability Finding: the end state (UNAUTHENTICATED, no key sent, no trusted video) is observable with Lauterbach, Saleae and Wireshark. "Does not retry indefinitely" needs a long observation time (define it).

Technical Finding: the concept says "configured maximum", the technical requirement says a fixed "three". Fixed or configurable, and where is it configured?

Structure Finding: see 103053.

Traceability Finding: MVC-106569. SRS MVC-108124 (terminate if data incomplete) is similar but not the same.

How to test

```
SIM never gives valid data; reset
Saleae: wait 60 s after the last retry       -> expect: no further auth requests, no key write
Lauterbach: read auth state                  -> expect: UNAUTHENTICATED
SIM then sends frames with a valid tag       -> expect: still rejected (see 119708)
Power cycle                                  -> expect: a new authentication attempt starts
```

Decision: OPEN

---

13. MVC-103040 (2.2.1.1.3-1), CAL 2, Test

> *Following successful authentication, The system shall extract 2048-bit device public key from the Imager's authentication data.*

Technical requirement: MVC-106577. Test: CS-SOW1-012.

SIQ: format of the key in the data (modulus only, fixed exponent?).

Impact and proposal: add sanity checks (length 2048 bits, odd modulus, exponent as defined) before the key is used.

Testability Finding: the extracted key is internal. Indirect check: SOW2 encrypts with it, and the SIM decrypts with its private key. If decryption works, the right key was used. Wrong-size or malformed keys signed with the test root key are easy to create.

Technical Finding: the key is covered by the signature only if Device_n is the key modulus (SIQ in entry 9). If it is not covered, a key swap is possible.

Structure Finding: NONE.

Traceability Finding: MVC-106577. SRS 23.2.4.4 (MVC-108153) uses "the authenticated SOW1 Device public key".

How to test

```
SIM: device key K1, signed by test root; authentication OK
SIM: decrypt the key block that SOW2 writes with K1_priv  -> expect: success (proves K1 was
used)
SIM: key of 1024 or 4096 bits, valid signature             -> expect: rejected, no key block
sent
SIM: truncated or all-zero key, valid signature            -> expect: rejected
Lauterbach (optional): compare the key buffer with K1
```

Decision: OPEN

---

14. MVC-103057 (2.2.1.1.3-2), CAL 2, Test

> *The system shall generate a 256-bit cryptographically random session key (SSK) following successful Imager authentication.*

Technical requirement: MVC-106568. Test: CS-SOW1-010.

Impact and proposal: "new key for every session" is in the verification criteria but not in the requirement text. Add it (SRS MVC-108110 says it).

Testability Finding: the SSK is only visible through the SIM (decrypting the key block). With a real imager it cannot be seen. Randomness cannot be proven by test, only checked for repeats.

Technical Finding: NONE.

Structure Finding: overlaps 103042 (how it is generated) and 103036 (new session needs a new key). Proposal: keep "256-bit, new each session" here and "how" in 103042.

Traceability Finding: MVC-106568. SRS MVC-108107, 108110.

How to test

```
loop 1000 times: reset -> authenticate -> SIM decrypts the key block -> store SSK
check: length = 32 bytes; no two SSKs equal; bit balance roughly 50 percent
SIM fails authentication -> Saleae: no key block is written
```

Decision: OPEN

---

15. MVC-103042 (2.2.1.1.3-3), CAL 2, Test

> *The system shall use a CSPRNG compliant with NIST SP 800-90A and seeded by a hardware TRNG to generate the 256-bit session key.*

Technical requirement: MVC-106560. Test: CS-SOW1-011.

SIQ (Ambarella): which DRBG and which TRNG interface is used, and is there evidence for SP 800-90A conformity and for the quality of the TRNG?

Impact and proposal: "compliant with SP 800-90A" is a design property, not testable from outside. Proposal: change the method to **Review** (design and code evidence), and keep a test only for the failure behaviour.

Testability Finding: black-box tests can only show uniqueness. Failure injection (TRNG returns an error) can be done by forcing the return value with Lauterbach.

Technical Finding: SP 800-90A defines the DRBG, not the entropy source (SP 800-90B). Reseeding is not mentioned. Proposal: add a reseed rule.

Structure Finding: overlaps the debug requirement MVC-103050 (also TRNG). Both depend on the same driver.

Traceability Finding: MVC-106560. SRS MVC-108106, 108109. Also SRS 23.1.1.2 (DTLS) uses the same source.

How to test

```
Review: CSPRNG library = SP 800-90A DRBG? seed source = SoC TRNG API? -> collect evidence
Lauterbach: breakpoint on TRNG read, force error  -> expect: session aborted, no key block on
I2C (Saleae)
collect 1000 SSKs via SIM                          -> expect: no repeat
```

Decision: OPEN

---

16. MVC-103055 (2.2.1.1.3-4), CAL 2, Test

> *The system shall encrypt the session key and selected row information using the 2048-bit device public key with RSAES-OAEP and SHA-256. (Note: row information format is defined by Samsung, chapter 5 Key sharing of the S5K3B6SA cybersecurity application note.)*

Technical requirements: MVC-106580, 106576, 108741, 106574. Tests: CS-SOW1-013, 007, 008, 009.

SIQ: message layout (SSK, Row_info_00, Row_info_01, sizes, order), OAEP label (empty?) and MGF1 hash. The Samsung note is not in the repo.

Impact and proposal: the layout is needed by implementation and test. Proposal: put the layout in the technical requirement.

Testability Finding: OAEP is randomised, so two encryptions of the same input differ. Compare plaintexts only: the SIM decrypts and checks the content. Injecting a known SSK needs a test hook (Lauterbach write before the encrypt call).

Technical Finding: capacity check: RSA-2048 with OAEP and SHA-256 carries at most 256 − 2×32 − 2 = 190 bytes, so a 32-byte key plus the row information fits if the row information is small. The row rules in the technical requirements (start 0 or 1, interval at least 10 or 30 by output mode, and the formula start + 1 + (interval + 1) × (total − 1) ≤ ysize_image + ysize_embedded_data) depend on the output mode, so the mode must be known to the code that builds Row_info.

Structure Finding: one concept requirement is satisfied by four technical requirements, three of which are about row selection and not about encryption. Proposal: a separate concept requirement for the row selection rules.

Traceability Finding: MVC-106580, 106576, 108741, 106574. SRS MVC-108153, 108145, 108165, 108166.

How to test

```
SIM (holds device private key): read the key block from I2C (Saleae / TE-1190)
PyRef: RSA-OAEP decrypt, SHA-256, MGF1-SHA-256  -> expect plaintext = SSK(32 B) || Row_info_00
|| Row_info_01
Lauterbach: read the Row_info SOW2 used          -> expect: equal to the decrypted Row_info
decrypt with another private key                 -> expect: fails
Saleae: search the bus capture for the SSK bytes -> expect: not found in plaintext
Row rules (one run each): start 2 / interval 9 in RAW12 / total too large (formula +1 row) ->
expect: configuration refused
```

Decision: OPEN

---

17. MVC-103034 (2.2.1.1.3-5), CAL 2, Test

> *The system shall transmit the 2048bit Encrypted Session Key and row information to the Imager for secure session establishment.*

Technical requirement: MVC-106578. Test: CS-SOW1-014.

SIQ: how does SOW2 learn that the imager accepted the key block? What is "the expected response" used in 103046?

Impact and proposal: no requirement says when a session counts as established. Without it 119708, 103046 and 103044 cannot be tested. Proposal: add one requirement, for example "the session is established when the imager acknowledges the key block and the first valid tagged frame is received".

Testability Finding: capturing the write on the SoC to deserializer I2C bus is possible. The message layout comes from the Samsung note.

Technical Finding: the Volvo spec configures "I2C CRC ON" for the C1-sample, so the transfer is protected by CRC at transport level. The key block of about 256 bytes may need several I2C writes: partial writes need a defined reaction.

Structure Finding: the concept says "transmit ... to the Imager", the technical requirement adds "over the I2C interface". Fine.

Traceability Finding: MVC-106578. SRS MVC-108146, 108145.

How to test

```
Saleae: after authentication OK, capture the writes to the imager key register(s) -> expect:
encrypted block, correct length
check order: auth read -> verify -> key write (no key write before auth OK)
SIM acknowledges                  -> Lauterbach: state = SESSION_ACTIVE
SIM stays silent                  -> state != SESSION_ACTIVE
```

Decision: OPEN

---

18. MVC-113706 (2.2.1.1.3-6), CAL 2, Test

> *The system shall not expose the active session key through any accessible interface during the active secure session.*

Technical requirement: MVC-106571. Test: CS-SOW1-015.

Impact and proposal: "any accessible interface" must be a list. Proposal: UART, JTAG (when unlocked), logs, SOME/IP and DTLS diagnostics, memory dumps, I2C, SPI flash.

Testability Finding: a negative test. It needs a list of interfaces and the SSK value (from the SIM) to search for.

Technical Finding: the SRS keeps the key in DRAM (MVC-108164). An authorised debug session (secure debug requirements) lets Lauterbach read DRAM, so the key would be readable through the debug interface. Either the debug unlock must exclude the key region, or this is an accepted exception. Please decide.

Structure Finding: the technical requirement duplicates the text. SRS has related requirements (MVC-108164, 108163, 108154, 108157).

Traceability Finding: MVC-106571. SRS MVC-108164, 108163, 108154, 108157. Related to the debug requirements and to DRAM protection (SRS 23.5).

How to test

```
SIM: get SSK value (decrypt the key block)
JTAG locked: attach with Lauterbach -> expect: denied
search captures for the SSK bytes: I2C (Saleae), Ethernet (Wireshark), UART log -> expect: not
found
trigger failures (bad frame, failed session) -> read logs and diagnostic responses -> expect:
no key bytes
authorised debug unlocked: Lauterbach read of the key region in DRAM -> record result; expect:
blocked, or an accepted exception
```

Decision: OPEN

---

19. MVC-103046 (2.2.1.1.3-7), CAL 2, Test

> *The system shall retry secure session establishment up to three times if the expected response is failed to be received.*

Technical requirement: MVC-106567. Test: CS-SOW1-016.

SIQ: what is the "expected response"? Timeout per try? On each retry, is the same encrypted block sent again, or a new SSK and a new block?

Impact and proposal: define response, timeout and what is sent again. Proposal: a new block (re-encrypted) with the same SSK, or a new SSK, but state it.

Testability Finding: counting retries with Saleae, SIM withholding the response. Nothing can be checked until the response is defined (entry 17).

Technical Finding: "three retries" is consistent with 103044 and with the technical requirements.

Structure Finding: NONE.

Traceability Finding: MVC-106567. SRS MVC-108149 (timeout or retry limit).

How to test

```
SIM: accept authentication, do not answer the key block
Saleae: count key block writes     -> expect: 1 + 3 (as decided)
SIM: answer on the 2nd write       -> expect: session established
```

Decision: OPEN

---

20. MVC-103044 (2.2.1.1.3-8), CAL 2, Test

> *The system shall terminate secure session establishment if a secure session is not successfully established after three retry attempts.*

Technical requirement: MVC-106581. Test: CS-SOW1-017.

SIQ (safety): the reaction after termination (no video, new full authentication later, safe state). Same question as entry 12.

Impact and proposal: define what happens next and whether the three retries are repeated after a full new authentication.

Testability Finding: the end state is observable: no active session, no more writes, the key not used.

Technical Finding: the SRS says partially established session data must be invalidated (MVC-108149). Check that the SSK from the failed attempt is erased, with Lauterbach reading the key buffer.

Structure Finding: NONE.

Traceability Finding: MVC-106581. SRS MVC-108149, 108158.

How to test

```
SIM: never acknowledges the key block
Saleae: after the last retry, wait 60 s            -> expect: no more key writes
Lauterbach: session state = INACTIVE; read key buffer -> expect: zeroed
SIM sends tagged frames                             -> expect: rejected
trigger a new attempt (reset)                       -> expect: authentication starts again
```

Decision: OPEN

21. MVC-103036 (2.2.1.1.3-9), CAL 2, Test

> *The system shall require establishment of a new secure session, including full SOW1 authentication and generation of a new session key (SSK), after session expiry, system reset, system restart, session termination, or detection of a security failure.*

Technical requirement: MVC-106573. Test: CS-SOW1-018.

SIQ

- Session lifetime: what is the expiry time? No requirement defines it.
- "Security failure": which events (one bad CMAC frame? ten? an I2C error?). SRS MVC-108158 says "video authentication failure requiring session recovery", which has no definition either.
- "System reset" and "system restart": what is the difference?

Impact and proposal: two of the five triggers cannot be tested without these definitions. This also conflicts with 119710 (reject the frame and continue, SRS MVC-108105): the line between "reject one frame" and "start a new session" is missing. Proposal: define a lifetime, a failure threshold (for example N bad frames within T seconds) and merge reset and restart.

Testability Finding: each trigger can be tested alone, as the verification criteria already say. Old key must be rejected afterwards: the SIM keeps sending frames with the old key.

Technical Finding: renegotiating while the camera streams: what happens to the video during the new authentication? Interruption time is not limited.

Structure Finding: several requirements in one (five triggers). Consider one requirement per trigger group, or keep it and give each trigger its own test (the technical test does this).

Traceability Finding: MVC-106573. SRS MVC-108156, 108158, 108151.

How to test

```
for trigger in [expiry, reset, restart, termination, security failure]:
    establish session; SIM sends frames with SSK_old -> accepted
    fire the trigger
    Saleae: new auth read + new key block     -> expect: yes
    SIM decrypts the new block: SSK_new != SSK_old
    SIM sends frames with SSK_old             -> expect: rejected
```

Decision: OPEN

---

22. MVC-119714 (2.2.1.1.5-1), CAL 2, Test

> *The system shall not transmit SOW1 control commands before successful SOW1 device authentication.*

Technical requirement: MVC-109119 ("protected SOW1 control commands"). Test: CS-SOW1-027.

SIQ: which commands are "control commands"? The imager has to be configured over I2C (for example the settings files in `SOW1/Imager Settings/`) and the authentication itself is I2C traffic. Which I2C writes are allowed before authentication?

Impact and proposal: read literally, the requirement forbids the writes needed to start the camera. The technical text says "protected" commands, the SRS too. Proposal: list the protected commands, or list the allowed pre-authentication ones, and use the word "protected" at concept level.

Testability Finding: Saleae can list all writes to the imager address. The pass criterion needs the list from the SIQ.

Technical Finding: the Volvo spec does not mention any protected command channel. See entry 23.

Structure Finding: concept says "SOW1 control commands", technical says "protected SOW1 control commands": two terms.

Traceability Finding: MVC-109119. SRS MVC-108169.

How to test

```
reset; SIM does not complete authentication
trigger a protected command (command source to confirm)
Saleae: list all I2C writes to the imager          -> expect: only the allowed pre-auth writes,
no protected command
repeat after authentication failure and before the key block was acknowledged
complete authentication + session; trigger again    -> expect: command sent
```

Decision: OPEN

---

23. MVC-113701 (2.2.1.1.5-2), CAL 2, Test

> *The system shall calculate a 128-bit AES-CMAC over each SOW1 control command using the established 256-bit session key.*

Technical requirement: MVC-108740. Test: CS-SOW1-028.

SIQ (Samsung, Bosch): does the imager verify a command tag at all? The Volvo spec section 11 does not describe it. SRS MVC-108160 adds the tag "only when protected control command verification is supported by SOW1". What are the command format and the CMAC input?

Impact and proposal: if the imager does not check it, the tag adds nothing. Proposal: confirm support first. If supported, put the exact input in the requirement (command, counter, order). The SRS says the counter is included before the tag is calculated (MVC-108159), so the counter is covered. The concept does not say it.

Testability Finding: the tag can be checked with PyRef from a captured command and the SSK. Whether the imager accepts or rejects a command with a wrong tag cannot be tested if the imager does not check.

Technical Finding: the concept says "each command", the SRS says "protected command only when supported". Conflict.

Structure Finding: 113701 (calculate), 119707 (append), 113702 (counter) are three steps of one function. Proposal: one requirement for the protected command format: command + counter + CMAC.

Traceability Finding: MVC-108740. SRS MVC-108160, 108159.

How to test

```
trigger a protected command (to confirm)
Saleae: capture the I2C write to the imager   -> parse: cmd | counter | tag
SIM: get SSK; PyRef: AES256-CMAC(SSK, cmd||counter)  -> expect: equals the tag on the bus
change one command byte, recompute with the same key -> tag differs
if the imager checks: send a command with a wrong tag -> expect: imager rejects it
```

Decision: OPEN

---

24. MVC-119707 (2.2.1.1.5-3), CAL 2, Test

> *The system shall append the calculated 128-bit AES-CMAC tag to each SOW1 control command before transmission.*

Technical requirement: MVC-106570. Test: CS-SOW1-029.

SIQ: the field order and size inside the I2C write. The Volvo spec sets I2C CRC ON for the C1-sample: where does the CRC go relative to the tag?

Impact and proposal: define the frame layout. Proposal: put it in the technical requirement with an example.

Testability Finding: easy with Saleae once the layout is defined.

Technical Finding: if CMAC generation fails, the command must not be sent (SRS MVC-108160). The concept does not say it. Add it.

Structure Finding: see 113701. The concept verification text says only "transmitted command contains the original command data"; the technical text checks field order and encoding.

Traceability Finding: MVC-106570. SRS MVC-108160.

How to test

```
Saleae: capture a protected command write   -> expect: [cmd][counter][16-byte tag] in the
defined order
```

```
Lauterbach: force CMAC calculation to fail  -> expect: no command is transmitted
repeat for 3 different commands
```

Decision: OPEN

---

25. MVC-113702 (2.2.1.1.5-4), CAL 2, Test

> *The system shall include a monotonically increasing Counter in each SOW1 control command transmitted.*

Technical requirement: MVC-109121. Test: CS-SOW1-030.

SIQ: counter width, start value, behaviour at the maximum, and does the imager check it?

Impact and proposal: "monotonically" allows equal values. Proposal: "strictly increasing" and no reuse within the session (SRS MVC-108161). The counter restarts with each session because the key changes: say so. State the wrap rule (new session before wrap).

Testability Finding: with Saleae the counter can be read from many commands. The maximum value case needs a test hook to preset the counter.

Technical Finding: replay protection exists only if the imager rejects old counters. If it does not check, the counter protects nothing. Same open point as 113701.

Structure Finding: see 113701.

Traceability Finding: MVC-109121. SRS MVC-108159, 108161.

How to test

```
send 100 protected commands; Saleae: read counter of each -> expect: strictly increasing, no
repeats
reset (new session)                                          -> counter restarts as defined
Lauterbach: preset counter near the max; send commands   -> expect: defined behaviour (new
session before wrap)
if the imager checks: replay an old command (old counter) -> expect: rejected
```

Decision: OPEN

Part 3. Findings that need your decision first

#	Topic	Where	Why it matters
1	Frames 1 to 17 have no tag	119709, 119708, 103033	Pass/fail is undefined and the text contradicts the Volvo spec
2	Retry versus attempt count	103053, 103051	Cannot count I2C requests without one number
3	Reaction to a failure (video off? safe state?)	119710, 119708, 103051, 103044	A cybersecurity failure can switch off a camera image
4	Freshness window can dead-lock the stream	113703	More than 3 lost frames blocks all later valid frames
5	Static signature, no challenge	107642	A copied authentication record passes step 2. Only the CMAC proves the private key, from frame 18 on
6	Session lifetime and "security failure" are undefined	103036	Two of five triggers are untestable
7	Do protected commands exist?	119714, 113701, 119707, 113702	The Volvo spec has none. The imager may not check them
8	Authorised debug can read the session key from DRAM	113706	Conflicts with the "no exposure" requirement
9	Samsung documents and a test root key	all	Without them the message layouts and the valid signatures cannot be produced